Quantum Bill of Materials

Acme Corp

Generated 2026-09-27T05:53:26.390258+00:00 · catalog v1 (5a06fc0a9f41...)

Readiness summary

Total crypto findings	31 across 10 distinct algorithms/protocols
Quantum-safe today (PQ_SAFE + HYBRID)	80.6%
Shor-vulnerable (existential break under a CRQC)	12.9%
Grover-weakened (margin reduction only)	6.5%
Already classically broken/deprecated	0.0%

Prioritised migration plan

#	Algorithm	Threat	Count	Exposure	Lifetime	Score	Replacement
1	AES (key size unknown) `AES-UNK`	GROVER	2	internet_facing	15y	137.7	Verify key size; use AES-256
2	X25519 `X25519`	SHOR	2	internal	1y	84.5	Hybrid X25519MLKEM768 now, ML-KEM-768 later
3	Ed25519 `ED25519`	SHOR	1	internal	1y	83.6	ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
4	RSA-3072 `RSA-3072`	SHOR	1	internal	1y	83.6	ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware
5	Hybrid KEM (classical+ML-KEM) `HYBRID-KEM`	HYBRID	5	internet_facing	15y	47.2	Later: pure ML-KEM where policy allows
6	ML-DSA (44/65/87) `ML-DSA`	PQ_SAFE	7	internet_facing	15y	19.3	none needed
7	SHA-256 `SHA-256`	PQ_SAFE	7	internet_facing	15y	19.3	none needed
8	TLS 1.3 (hybrid PQ key exchange configured) `TLS1.3-HYBRID`	HYBRID	2	internal	1y	9.2	none needed -- verify the hybrid group is actually negotiated, not just configured
9	AES-256 `AES-256`	PQ_SAFE	2	internal	1y	3.7	none needed
10	ChaCha20(-Poly1305) `CHACHA20`	PQ_SAFE	2	internal	1y	3.7	none needed

Detail per item

1. AES (key size unknown) `(AES-UNK)` — *score 137.7*

Grover-weakened: effective security roughly halves under a large quantum computer; raise key/output size, no protocol redesign needed.

Occurrences: 2

Affected components: payments-svc, vault-svc

Recommended replacement: Verify key size; use AES-256

Locations: demo-run/workdir/app/crypto/vault.py:16, demo-run/workdir/app/payments/service.py:21

2. X25519 `(X25519)` — *score 84.5*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 2

Recommended replacement: Hybrid X25519MLKEM768 now, ML-KEM-768 later

Locations: demo-run/workdir/config/nginx.conf:4, demo-run/workdir/config/openssl.cnf:6

3. Ed25519 `(ED25519)` — *score 83.6*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 1

Recommended replacement: ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: demo-run/workdir/config/sshd_config:5

4. RSA-3072 `(RSA-3072)` — *score 83.6*

Shor-breakable: an attacker recording traffic/data today can decrypt it once a CRQC exists. Data here must stay confidential 1y, against a ~10y conservative planning horizon.

Occurrences: 1

Recommended replacement: ML-KEM-768 (FIPS 203); in TLS/SSH use hybrid X25519MLKEM768 first / ML-DSA-65 (FIPS 204); SLH-DSA (FIPS 205) for long-lived roots/firmware

Locations: demo-run/workdir/config/openssl.cnf:2

5. Hybrid KEM (classical+ML-KEM) `(HYBRID-KEM)` — *score 47.2*

Already hybrid classical+PQ; low urgency, monitor for pure-PQ migration once policy allows.

Occurrences: 5

Affected components: payments-svc, vault-svc

Recommended replacement: Later: pure ML-KEM where policy allows

Locations: demo-run/workdir/config/sshd_config:2, demo-run/workdir/config/nginx.conf:4, demo-run/workdir/config/openssl.cnf:6, demo-run/workdir/app/crypto/vault.py:9, demo-run/workdir/app/payments/service.py:14

6. ML-DSA (44/65/87) `(ML-DSA)` — *score 19.3*

Already quantum-safe with adequate margin.

Occurrences: 7

Affected components: payments-svc, vault-svc

Recommended replacement: none needed

Locations: demo-run/workdir/certs/modern_service.crt:1, demo-run/workdir/certs/legacy_partner.crt:1, demo-run/workdir/certs/legacy_partner.key:1, demo-run/workdir/certs/modern_service.key:1, demo-run/workdir/app/api/AuthService.java:7, demo-run/workdir/app/crypto/vault.py:13, demo-run/workdir/app/payments/service.py:10

7. SHA-256 (SHA-256) — *score 19.3*

Already quantum-safe with adequate margin.

Occurrences: 7

Affected components: legacy-batch, payments-svc, vault-svc

Recommended replacement: none needed

Locations: demo-run/workdir/web-service/crypto-utils.js:4, demo-run/workdir/web-service/crypto-utils.js:8, demo-run/workdir/app/api/AuthService.java:12, demo-run/workdir/app/crypto/vault.py:21, demo-run/workdir/app/payments/service.py:17, demo-run/workdir/app/legacy/hash.py:4, demo-run/workdir/app/legacy/hash.py:7

8. TLS 1.3 (hybrid PQ key exchange configured) (TLS1.3-HYBRID) — *score 9.2*

Already hybrid classical+PQ; low urgency, monitor for pure-PQ migration once policy allows.

Occurrences: 2

Recommended replacement: none needed -- verify the hybrid group is actually negotiated, not just configured

Locations: demo-run/workdir/config/nginx.conf:3, demo-run/workdir/config/openssl.cnf:5

9. AES-256 (AES-256) — *score 3.7*

Already quantum-safe with adequate margin.

Occurrences: 2

Recommended replacement: none needed

Locations: demo-run/workdir/web-service/crypto-utils.js:12, demo-run/workdir/config/sshd_config:3

10. ChaCha20(-Poly1305) (CHACHA20) — *score 3.7*

Already quantum-safe with adequate margin.

Occurrences: 2

Recommended replacement: none needed

Locations: demo-run/workdir/config/sshd_config:3, demo-run/workdir/config/nginx.conf:5